

ATT&CK Based Practice Guide Evaluation

Progress Report Presentation



Team:

Anmol Agarwal, Rhiannon Jones and
Evelyn Wong

Mentor:

Dr. Bhavani Thuraisingham
Brian Ricks

MITRE

Sponsor:

Harry Perper,
Department Chief Engineer (P1A1)
The MITRE Corporation

Overview

- Project Summary
- ARM Architecture
- ATT&CK Framework
- Attacks
- Expectations

Project Summary

Description

- Identify security gaps in the NCCoE Access Rights Management Practice Guide
- Use tactics and techniques in the MITRE ATT&CK Enterprise Matrix
- Perform tabletop exercise
 - Design theoretical attacks against the architecture to bypass the security features

ARM Architecture

ARM Architecture

Figure 4-2 ARM Reference Design

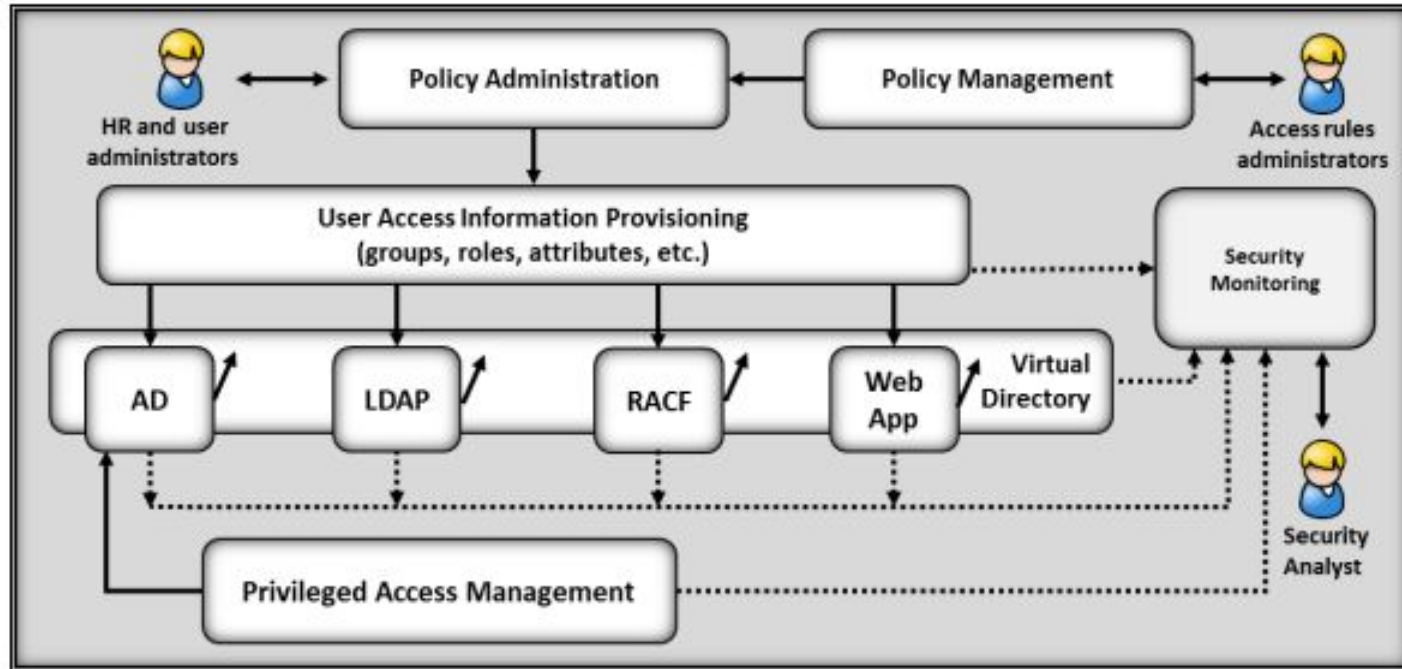


Figure from [4]

Our Focus

- We are focused on the Active Directory and Virtual Directory policies
 - Active Directory, AlertEnterprise, and RadiantLogic work together to ensure correct access rights policies
- We want to understand how these products work and what alerts they generate
 - Aim to bypass alerts

ATT&CK Framework

Initial Access	Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	Discovery	Lateral Movement	Collection	Exfiltration	Command and Control
Hardware Additions		Scheduled Task		Binary Pidding	Credentials in Registry	Browser Bookmark Discovery	Exploitation of Remote Services	Data from Information Repositories	Exfiltration Over Physical Medium	Remote Access Tools
Trusted Relationship		LSASS Driver		Extra Window Memory Injection	Exploitation for Credential Access	Network Share Discovery	Distributed Component Object Model	Video Capture	Exfiltration Over Command and Control Channel	Port Knocking
Supply Chain Compromise		Local Job Scheduling		Access Token Manipulation	Forced Authentication	Discovery	Remote File Copy	Automated Collection		Multi-hop Proxy
Spearphishing Attachment		Trap		Bypass User Account Control	Hooking	Peripheral Device Discovery	Pass the Ticket			Data Encoding
		Launchctl		Process Injection	Password Filter DLL		File and Directory Discovery	Clipboard Data	Data Encrypted	Remote File Copy
Exploit Public-Facing Application		Signed Binary		Image File Execution Options Injection	LLMNR/NBT-NS Poisoning	Keychain	Replication Through Removable Media	Email Collection	Automated Exfiltration	Multi-Stage Channels
		Proxy Execution		Plist Modification		Input Prompt	Windows Admin Shares	Screen Capture	Exfiltration Over Other	Web Service
		User Execution		Valid Accounts	Private Keys	Permission Groups	Data Staged	Network Medium	Exfiltration Over	Standard
Replication Through Removable Media		Exploitation for Client Execution		DLL Search Order Hijacking	Keychain	Process Discovery	Input Capture	Network Layer Protocol	Exfiltration Over	Non-Application Layer Protocol
		AppCert DLLs		Hooking	Input Prompt	System Network Connections Discovery	Third-party Software	Data from Network	Data Transfer	Connection Proxy
Spearphishing via Service		CMSTP		Startup Items	Bash History	System Owner/User Discovery	Shared Webroot	Shared Drive	Size Limits	Multi-layer Encryption
Spearphishing Link		Muhta		Launch Daemon	Port Knocking	System Network Connections Discovery	Logon Scripts	Data from Local System	Data Compressed	Standard Application
Drive-by Compromise		AppleScript		Dylib Hijacking	Indirect Command Execution	System Network Configuration Discovery	Windows Remote Management	Man in the Browser	Scheduled Transfer	Layer Protocol
Valid Accounts		Source		Application Shimming	BITS Jobs	Application Window Discovery	SSH Hijacking	Data from Removable Media		Commonly Used Port
		Space after Filename		Applied DLLs	Replication Through Removable Media	Configuration Discovery	Deployment Software			Standard Cryptographic Protocol
		Execution through Module Load		Web Shell	Control Panel Items	Input Capture	SSH Hijacking			Custom Cryptographic Protocol
		Regsvcs/Regasm		Service Registry Permissions Weakness	CMSTP	Network Sniffing	AppleScript			Data Obfuscation
		InstallUtil		New Service	Process Doppelganging	Credential Dumping	Password Policy	Taint Shared Content		Custom Command and Control Protocol
		Regsvr32		File System Permissions Weakness	Muhta	Xerbonsteering	Remote Desktop Protocol			Communication Through Removable Media
		Execution through API		Path Interception	Hidden Files and Directories	SecurityId Memory	System Time Discovery			Multiband Communication
		PowerShell		Accessibility Features	Space after Filename	Brute Force	Account Discovery			Fallback Channels
		RunDll32		Port Monitors	LC MAIN Hijacking	Account Discovery	System Information			Uncommonly Used Port
		Third-party Software		Kernel Modules and Extensions	Sudo History Injection	Credentials in Files	Discovery			
		Scripting		Port Knocking	Sudo		Security Software Discovery			
		Graphical User Interface		SIP and Trust	Setuid and Setgid		Network Service Scanning			
		Command-Line Interface		Provider Hijacking	Exploitation for Privilege Escalation		Remote System Discovery			
		Service Execution		Screensaver	Hidden Window		Query Registry			
		Windows Remote Management		Browser Extensions	Deobfuscate/Decode Files or Information		System Service Discovery			
		Signed Script		Re-opened Applications	Trusted Developer Utilities					
		Proxy Execution		Rc common	Component Object Model Hijacking					
		Control Panel Items		Login Item	InstallUtil					
		Trusted Developer Utilities		LC_LOAD_DYLIB Addition	Regsvr32					
		Windows Management Instrumentation		Hidden Files and Directories	Code Signing					
				Office Application Startup	Modify Registry					
				External Remote Services	Component Firmware					
				Netsh Helper DLL	Redundant Access					
				Component Object Model Hijacking	File Deletion					
				Redundant Access	Web Service					
				Security Support Provider	Timestamp					
				Bootkit	NTFS File Attributes					
				Hypervisor	Process Hollowing					
				Registry Run Keys / Start Folder	Disabling Security Tools					
				Login Scripts	RunDll32					
				Modify Existing Service	DLL Side-Loading					
				Shortcut Modification	Indicator Removal on Host					
				System Firmware	Scripting					
				Winlogon Helper DLL	Indicator Blocking					
				Time Providers	Software Packing					
				BITS Jobs	Masquerading					
				Launch Agent	Obfuscated Files or Information					
				.bash_profile and .bashrc	Signed Binary					
				Create Account	Proxy Execution					
				Authentication Package	Exploitation for Defense Evasion					
				Component Firmware	SIP and Trust Provider Hijacking					
				Windows Management Instrumentation	Launchctl					
				Event Subscription	Install Root Certificate					
				Change Default File Association	Network Share Connection Removal					
					Regsvcs/Regasm					
					Indicator Removal from Tools					
					Rootkit					

THE MITRE ATT&CK™ ENTERPRISE FRAMEWORK

ATTACK.MITRE.ORG

ATT&CK™

MITRE

About ATT&CK

- Knowledge base of adversary tactics and techniques
 - Based on real-world observations
 - Used as a foundation for developing specific threat models
- Attack categories
 - **Initial Access**
 - Execution
 - Persistence
 - **Privilege Escalation**
 - Defense Evasion
 - **Credential Access**
 - Discovery
 - Lateral Movement
 - Collection
 - Command and Control
 - Exfiltration
 - Impact

Attacks

Possible Attacks

- Phishing attack to get valid credentials
 - Use the credentials to login and then escalate the user's privileges
 - If the credentials have admin permissions, no need to escalate privileges
- Insider threat
 - Someone with valid credentials escalates their own privileges
 - User adds admin account for himself
- Exploit a vulnerability to gain access to the system
 - Escalate privileges
- Change all directory entries
 - Use escalated privileges while changes are being triaged
- Trick AlertEnterprise into thinking approval process happened
 - Make yourself the approval authority
 - Access owner approves access

Plans for the Future /
Expected Outcome

Schedule

October 4:	Proposal Due
October 11:	Review the Access Rights Management Practice Guide
October 18:	Review ATT&CK Matrix
October 25:	Plan Tabletop Exercise
November 1:	Midterm Report Due
November 8:	Perform Tabletop Exercise
November 15:	Finish Tabletop Exercise
November 15:	Report Draft of Tabletop Exercise
November 22:	Review Final Report
December 6:	Final Deliverables Due

Expected Outcome

- Find at least one attack that successfully bypasses ARM security policies
- Complete tabletop exercises with various attacks
 - Successful and unsuccessful attacks

References

- [1] B. Strom, A. Applebaum, D. Miller, K. Nickels, A. Pennington and C. Thomas. (2018). “MITRE ATT&CK™: Design and Philosophy,” [online] McLean, VA: MITRE Corporation. Available at: <https://www.mitre.org/sites/default/files/publications/pr-18-0944-11-mitre-attack-design-and-philosophy.pdf> [Accessed 27 Sep. 2019].

- [2] B. E. Strom, J. A. Battaglia, M. S. Kemmerer, W. Kupersanin, D. P. Miller, C. Wampler, S. M. Whitley and R. D. Wolf, “Finding Cyber Threats with ATT&CK-Based Analytics,” 2017. Available at: <https://www.mitre.org/sites/default/files/publications/16-3713-finding-cyber-threats%20with%20att&ck-based-analytics.pdf> [Accessed 27 Sep. 2019].

- [3] F. Maymí, R. Bixler, R. Jones and S. Lathrop, "Towards a definition of cyberspace tactics, techniques and procedures," 2017 IEEE International Conference on Big Data (Big Data), Boston, MA, 2017, pp. 4674-4679. doi: 10.1109/BigData.2017.8258514. Available at: <https://ieeexplore.ieee.org/abstract/document/8258514> [Accessed 27 Sep. 2019].

References

- [4] J. Banoczi, S. Edwards, N. Irrechukwu, J. Klosterman, H. Perper, S. Prince, S. Symington, and D. Wynne, “Access Rights Management for the Financial Services Sector,” National Institute of Standards and Technology Special Publication, Gaithersburg, MD, 2017.
- [5] The MITRE Corporation. (2019). CALDERA. [online] Available at: <https://www.mitre.org/research/technology-transfer/open-source-software/caldera> [Accessed 27 Sep. 2019].
- [6] The MITRE Corporation. (2019). MITRE ATT&CK Matrix Poster. [online] Available at: https://attack.mitre.org/docs/ATTACK_Framework_Board_4x3.pdf [Accessed 29 Oct. 2019].